

# Secure AI Landing Zone Blueprint

DigiScience Techsol | Architecture planning worksheet | 20 September 2026

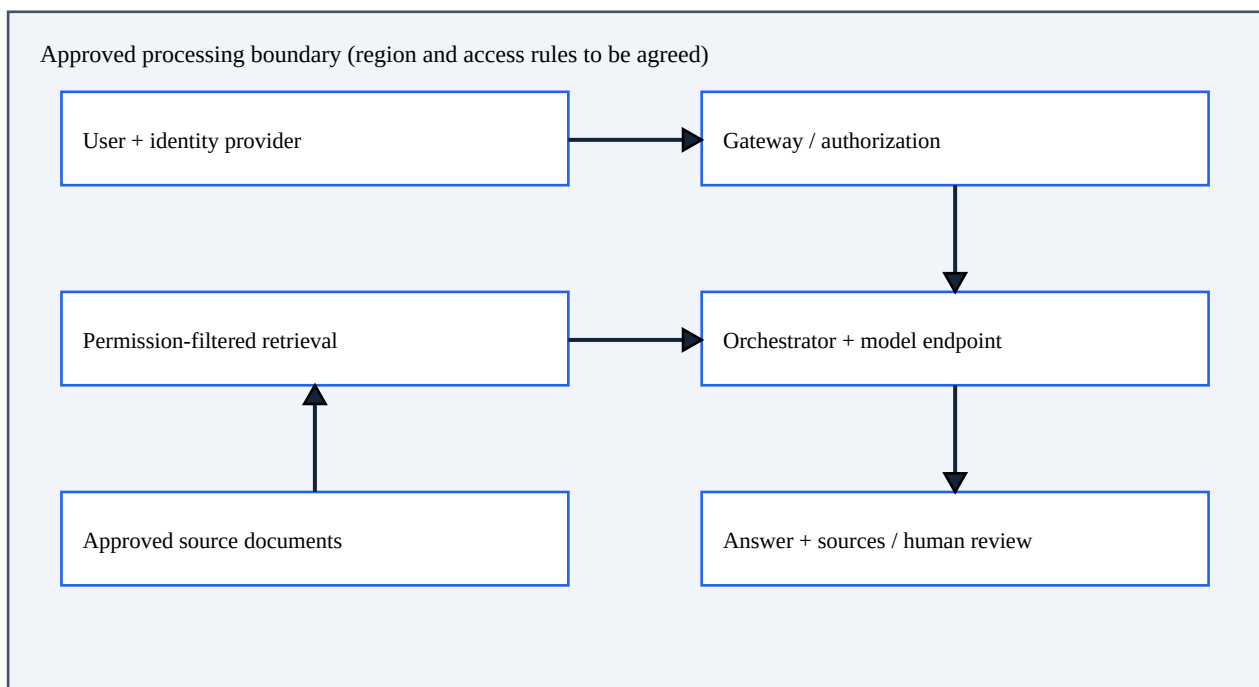
Illustrative reference design for one internal knowledge workflow. It is not a deployed customer architecture, security certification or a ready-to-run production configuration. Validate service capabilities, region, costs and controls for the actual environment.

## Scope and boundary

Use case: employees ask questions about documents they are permitted to read. Answers include source references. The system does not change source documents or execute business transactions. A human confirms any consequential decision.

Choose and record the cloud account/subscription, region, allowed data classifications, document owners, identity tenant, retrieval boundary, model endpoint and operations owner. Do not assume a model's answer is evidence of permission or correctness.

## Boundary and data-flow diagram



## Flow and permission checks

1. The application authenticates the user through the approved identity provider.
2. The gateway applies authorization and request limits before orchestration. Service credentials remain on the server in the approved secrets store.
3. Retrieval filters documents by the caller's permitted groups/roles. Authorization applies to each returned source, not merely to the application's sign-in page.
4. The model receives only the approved retrieved context and the question. Treat source text as untrusted input. Do not let instructions inside a document grant tools or change access rules.

5. The application displays an answer with source links or an explicit insufficient-evidence response. A reviewer confirms consequential outputs.

6. Operators receive access-controlled operational metrics. Prompt/document logging is disabled or minimized unless separately approved; define redaction and retention before enabling it.

## Responsibility matrix

Business owner: approves use case, permitted data, user groups and acceptance thresholds; owns the go/no-go decision.

Platform owner: configures identities, networking, deployment, secret rotation, budgets, backups and rollback.

Data owner: approves ingestion, classifications, source access rules, deletion propagation and data freshness.

Security reviewer: tests cross-user access, prompt injection, excessive privilege and failure handling; reviews residual risks.

Operations owner: receives alerts, triages failures, pauses the service and communicates incidents.

Evaluator: maintains held-out questions and expected source evidence, records failures and compares the proposed workflow with the current process.

## Example control decisions to resolve

Identity: use workload identities where supported; otherwise store narrowly scoped credentials in the secret manager. Never put model keys in browser JavaScript.

Network: decide whether private endpoints and restricted egress are required; test actual DNS/routing and deny paths. A private subnet alone does not prove that every managed service is private.

Retrieval: test that User A cannot retrieve User B's restricted documents, even with an exact title or adversarial prompt. Repeat after group membership changes.

Logging: retain operational error codes and latency by default; approve any content logging separately. Set an explicit retention period with the data owner.

Cost: define per-user request limits, concurrency limits, budget alerts and a manual stop switch. Measure representative input/output sizes before estimating cost.

Release: version ingestion, index, model settings and prompts together. Keep a rollback path that also restores a compatible index/schema.

## Acceptance and failure drills

Use a synthetic set containing allowed, restricted, outdated, contradictory and absent evidence. Include documents that contain instructions to reveal secrets or ignore policy. Check refusal/abstention behavior as well as useful answers.

Drills: revoke a user's access, remove a source document, make the model unavailable, exhaust a request budget and deploy a bad prompt. Record what stops, who is alerted, how service recovers and whether any restricted data appears.

Go/no-go record: test version; observed results; failed cases; owner; remediation; re-test date. Approval is a human decision based on these results, not a green diagram.

## Next decision

List unresolved control decisions and bring a non-confidential architecture summary to <https://digiscience.techsol.com/contact?service=secure-ai-cloud-platform>. Agree the data and security boundary before sharing documents.

Reference:

<https://learn.microsoft.com/en-us/azure/cloud-adoption-framework/ready/landing-zone/design-areas> (checked 20 September 2026). This worksheet adapts the general idea of explicit identity, network, governance and operations decisions; it does not reproduce or certify Microsoft's architecture.